50 Cybersecurity & VAPT Interview Questions and Answers

Linux • Networking • Nmap • Web Security • Burp Suite • Core Security Concepts

Format: Every question has exactly six concise answer points, designed for interview revision and command practice.

Important: *Commands and testing examples are for systems you own or are explicitly authorized to assess. Follow the approved scope and avoid destructive testing.*

How to use this PDF

Answer each question aloud first, then compare your response with the six points. For command questions, explain what the command does, what the key option means, and what the result does—and does not—prove.

Security fundamentals

Q1. What is cybersecurity?

1. Cybersecurity protects systems, networks, applications, and data from unauthorized access or damage.
2. It aims to preserve confidentiality, integrity, and availability (the CIA triad).
3. Common threats include malware, phishing, credential theft, and exploitation of vulnerabilities.
4. Controls include access management, encryption, patching, monitoring, and backups.
5. Security is a continuous process involving prevention, detection, response, and recovery.
6. Example: multi-factor authentication reduces the risk of account compromise.

Q2. What is VAPT?

1. VAPT means Vulnerability Assessment and Penetration Testing.
2. Vulnerability assessment identifies and prioritizes potential weaknesses.
3. Penetration testing safely attempts to validate whether weaknesses can be exploited.
4. Assessment is usually broader; penetration testing is deeper and evidence-driven.
5. Typical phases include scope definition, reconnaissance, scanning, validation, reporting, and retesting.
6. Testing must have explicit authorization and a defined scope.

Q3. What is the difference between a vulnerability, threat, and risk?

1. A vulnerability is a weakness in a system or process.
2. A threat is something capable of exploiting a weakness and causing harm.
3. Risk combines the likelihood of an event with its potential impact.
4. A missing security patch is a vulnerability; an attacker is a threat.
5. Risk increases when a likely threat can exploit a high-impact weakness.
6. Prioritize remediation by severity, exposure, exploitability, and business impact.

Q4. What is Linux, and why is it used in security?

1. Linux is an open-source, Unix-like operating system.
2. It provides powerful command-line tools for administration, automation, and investigation.
3. Kali Linux bundles many tools used for authorized security testing.
4. Permissions and ownership help control access to files and processes.
5. Logs, process tools, networking utilities, and package managers support troubleshooting.
6. Knowing Linux fundamentals matters more than memorizing a specific distribution.

Linux commands and administration

Q5. How do you list files and directories in Linux?

1. `ls` lists directory contents.
2. `ls -l` displays permissions, owner, group, size, and modification time.
3. `ls -a` includes hidden entries whose names begin with a dot.
4. `ls -lh` shows file sizes in a human-readable format.
5. `pwd` prints the current working directory.
6. `find /path -type f -name 'name'` searches for files matching a name.

Q6. How do you navigate the Linux filesystem?

1. `pwd` shows the current directory.
2. `cd /path` moves to an absolute path.
3. `cd ..` moves to the parent directory.
4. `cd ~` moves to the current user's home directory.
5. `mkdir -p a/b` creates nested directories as needed.
6. `tree` displays a directory hierarchy when the utility is installed.

Q7. How do you read files from the terminal?

1. `cat file.txt` prints the whole file; best for short files.
2. `less file.txt` allows interactive scrolling through a file.
3. `head -n 20 file.txt` prints the first 20 lines.
4. `tail -n 20 file.txt` prints the last 20 lines.
5. `tail -f /var/log/example.log` follows new log entries.
6. `grep -n 'error' file.txt` searches matching lines and shows line numbers.

Q8. Explain Linux file permissions.

1. Permissions are represented for owner, group, and others.
2. `r` means read, `w` means write, and `x` means execute or directory traversal.
3. `chmod` changes permission bits; for example, `chmod 640 file`.
4. `chown user:group file` changes ownership when authorized.
5. `ls -l` displays permissions, such as `-rw-r--r--`.
6. Use least privilege; avoid broad permissions such as `chmod 777`.

Q9. What is the difference between chmod and chown?

1. `chmod` changes read, write, and execute permissions.
2. `chown` changes the file owner and optionally the group.
3. `chmod 755 script.sh` gives owner full access and others read/execute access.
4. `chown alice:dev file.txt` sets owner to alice and group to dev, if permitted.
5. Ordinary users generally cannot change ownership to arbitrary users.
6. Use `sudo` only when required and authorized.

Q10. How do you inspect running processes?

1. `ps aux` lists processes and their resource/user information.
2. `top` provides a live process and resource view.
3. `pgrep name` finds process IDs by name.
4. `kill PID` requests a process to terminate; it normally sends SIGTERM.
5. `kill -9 PID` sends SIGKILL and should be a last resort.
6. Verify the process identity before terminating it.

Q11. How do you inspect Linux logs?

1. `journalctl` queries the systemd journal.
2. `journalctl -u ssh` filters logs for a named service.
3. `journalctl -b` shows logs from the current boot.
4. `/var/log/` commonly contains application and system logs, depending on the distribution.
5. `grep` and `less` help search and review text logs.
6. Correlate timestamps, users, source addresses, and event types during investigation.

Q12. What is an IP address?

1. An IP address identifies a network interface for IP communication.
2. IPv4 uses 32 bits, usually written as four decimal octets.
3. Each IPv4 octet ranges from 0 to 255.
4. IPv6 uses 128 bits and is written in hexadecimal groups.
5. Private IPv4 ranges include 10.0.0.0/8, 172.16.0.0/12, and 192.168.0.0/16.
6. An IP address can be assigned dynamically by DHCP or configured statically.

Q13. Explain DNS and nslookup.

1. DNS translates domain names into records such as IP addresses.
2. `nslookup example.com` queries DNS for a domain.
3. `nslookup example.com 8.8.8.8` asks a specified DNS resolver.
4. A records map names to IPv4; AAAA records map names to IPv6.
5. MX records identify mail exchangers; TXT records can carry verification and email-security data.
6. A DNS response does not prove that a host is reachable or that a port is open.

Q14. What is the difference between TCP and UDP?

1. TCP is connection-oriented and provides ordered, reliable byte-stream delivery.
2. UDP is connectionless and does not guarantee delivery, ordering, or retransmission.
3. TCP uses a three-way handshake: SYN, SYN-ACK, ACK.
4. DNS commonly uses UDP, but can also use TCP; applications determine transport needs.
5. TCP is common for HTTPS, SSH, and many application protocols.
6. UDP is common for latency-sensitive traffic such as voice/video and some discovery protocols.

Networking fundamentals

Q15. Explain the TCP three-way handshake.

1. The client sends SYN to request a TCP connection.
2. The server responds with SYN-ACK if it accepts the request.
3. The client sends ACK to complete the handshake.
4. This synchronizes initial sequence numbers and establishes connection state.
5. A SYN scan examines SYN responses without completing a normal full connection.
6. Firewalls, packet loss, and rate limits can affect observed scan results.

Q16. What are common ports you should know for interviews?

1. 21/TCP: FTP control; traditional FTP may expose credentials without encryption.
2. 22/TCP: SSH for secure remote administration and file transfer.
3. 25/TCP: SMTP relay/transfer; 53: DNS, commonly UDP and sometimes TCP.
4. 80/TCP: HTTP; 443/TCP: HTTPS.
5. 110/TCP: POP3; 143/TCP: IMAP; encrypted variants commonly use other ports.
6. 3306/TCP is commonly MySQL and 3389/TCP is commonly RDP; port numbers alone do not prove service identity.

Q17. How do you inspect network configuration in Linux?

1. `ip addr` shows interfaces and assigned addresses.
2. `ip link` shows network interfaces and their link state.
3. `ip route` shows routing decisions and the default gateway.
4. `ping host` tests ICMP reachability when permitted.
5. `ss -tulpen` shows listening TCP/UDP sockets and associated process details where permissions allow.
6. `ip neigh` displays the neighbor cache, commonly including IPv4 ARP entries.

Q18. What is Nmap?

1. Nmap is a network discovery and security auditing tool.
2. It can identify live hosts, open ports, services, versions, and sometimes operating systems.
3. `nmap target` performs a default scan of common TCP ports.
4. `nmap -sV target` attempts service/version detection.
5. `nmap -oN scan.txt target` saves normal output to a file.
6. Scan only systems you own or are explicitly authorized to assess.

Q19. How do you discover live hosts with Nmap?

1. `nmap -sn 192.168.1.0/24` performs host discovery without a port scan.
2. `-sn` means skip port scanning; discovery methods depend on privileges and network conditions.
3. `nmap -Pn target` skips host discovery and treats the target as online for scanning.
4. `-Pn` can help when discovery probes are blocked, but may make scanning slower.
5. Firewalls and ICMP filtering can cause live hosts to appear unavailable.
6. Use the correct CIDR range and stay within the approved scope.

Q20. Explain important Nmap scan types.

1. `-sS` performs a TCP SYN scan, often requiring elevated privileges for raw packets.
2. `-sT` uses the operating system's TCP connect call.
3. `-sU` scans UDP ports and can be slow or ambiguous.
4. `-sV` probes open ports to identify services and versions.
5. `-O` attempts operating-system detection and works best with suitable responses and privileges.
6. Scan types have different visibility, accuracy, permissions, and network impact.

Q21. How do you scan specific ports with Nmap?

1. `nmap -p 22,80,443 target` scans the listed TCP ports.
2. `nmap -p 1-1000 target` scans a range of ports.
3. `nmap -p- target` scans all 65,535 TCP ports.
4. `nmap -sU -p 53 target` checks UDP port 53.
5. `nmap -F target` scans a smaller set of common ports.
6. Specify TCP or UDP expectations clearly; a TCP scan does not establish UDP port status.

Q22. What do Nmap port states mean?

1. `open` means an application is accepting connections or responding on that port.
2. `closed` means the host is reachable but no application is listening on that port.
3. `filtered` means Nmap cannot determine the state because filtering or a network obstacle blocks probes.
4. `open|filtered` means Nmap cannot distinguish an open port from a filtered one.
5. `unfiltered` means a port is accessible to the probe but its open/closed state is not determined by that scan type.
6. Results are observations from a particular vantage point, not permanent facts about a host.

Q23. How do you save Nmap scan results?

1. `nmap -oN result.txt target` saves human-readable normal output.
2. `nmap -oX result.xml target` saves XML output for tools and parsing.
3. `nmap -oG result.gnmap target` saves grepable output, a legacy format.
4. `nmap -oA audit target` writes normal, XML, and grepable outputs with a shared basename.
5. Keep timestamps, scope, scan options, and tool versions with the results.
6. Store scan files securely because they may reveal sensitive infrastructure details.

Nmap and reconnaissance

Q24. What is Nmap service and OS detection?

1. `-sV` sends probes to identify services and possible versions.
2. `-O` uses TCP/IP stack characteristics to estimate the operating system.
3. `-A` enables OS detection, version detection, default scripts, and traceroute.
4. Detection can be inaccurate when services are proxied, customized, or filtered.
5. Version results help identify potentially vulnerable software, but require validation.
6. Use aggressive options only when they fit the authorized test plan.

Q25. What is Nmap NSE?

1. NSE means Nmap Scripting Engine.
2. It runs scripts to support discovery, service checks, and selected security tests.
3. `nmap -sC target` runs the default script set.
4. `nmap --script scriptname target` runs a named script.
5. Script categories differ in behavior and risk; read script documentation before use.
6. Some scripts are intrusive, so choose them only when explicitly permitted.

Q26. What is the difference between a port scan and a vulnerability scan?

1. A port scan identifies reachable hosts and port states.
2. Service detection attempts to identify software listening on ports.
3. A vulnerability scan checks for known weaknesses using signatures or tests.
4. A penetration test validates exploitability within an agreed scope.
5. An open port is not automatically a vulnerability.
6. Combine technical evidence with version verification, configuration review, and impact analysis.

Q27. What is HTTP and HTTPS?

1. HTTP is an application-layer protocol used to exchange web requests and responses.
2. HTTPS is HTTP protected by TLS.
3. HTTP messages include methods, headers, and sometimes a body.
4. Common methods include GET, POST, PUT, PATCH, and DELETE.
5. TLS helps provide confidentiality, integrity, and server authentication when correctly configured.
6. HTTPS does not automatically prevent SQL injection, broken access control, or insecure business logic.

Q28. What are HTTP status code classes?

1. 1xx indicates informational responses.
2. 2xx indicates success; 200 means OK and 201 commonly means Created.
3. 3xx indicates redirection; 301 and 302 are common redirect statuses.
4. 4xx indicates client-side request issues; 400, 401, 403, and 404 are common examples.
5. 5xx indicates server-side failures; 500 and 503 are common examples.
6. Interpret the status code with response headers, body, and application behavior.

Q29. What is Burp Suite?

1. Burp Suite is a platform for testing web application security.
2. Burp Proxy lets testers inspect and modify HTTP/S traffic between a browser and an application.
3. Repeater allows manual resending and modification of individual requests.
4. Intruder automates customized request variations for controlled testing.
5. HTTP history and site map help understand application endpoints and traffic.
6. Use it only against authorized applications and test accounts.

Web security and common controls

Q30. What is an intercepting proxy?

1. It sits between a client and server and can inspect requests and responses.
2. Burp Proxy can pause traffic so the tester can review or modify it.
3. The browser must be configured to route traffic through the proxy.
4. HTTPS inspection requires trusting the proxy's certificate in the testing browser/profile.
5. Intercepting can break normal flows, so disable it when not actively inspecting.
6. Never install a testing CA certificate into a device or profile where it is not appropriate.

Q31. What is SQL injection?

1. SQL injection occurs when untrusted input changes the structure of a database query.
2. It often results from building SQL with unsafe string concatenation.
3. Impact can include data disclosure, authentication bypass, or data modification.
4. Parameterized queries/prepared statements are the primary defense.
5. Server-side validation and least-privilege database accounts add defense in depth.
6. Test only with authorization and use non-destructive proof wherever possible.

Q32. What is cross-site scripting (XSS)?

1. XSS occurs when attacker-controlled content executes as script in another user's browser.
2. Reflected XSS comes from a request and is reflected in the response.
3. Stored XSS persists in application data and later affects users.
4. DOM-based XSS arises from unsafe client-side DOM handling.
5. Context-aware output encoding and safe DOM APIs are key defenses.
6. Content Security Policy can reduce impact but is not a substitute for fixing the root cause.

Q33. What is CSRF?

1. Cross-Site Request Forgery tricks an authenticated browser into sending an unwanted request.
2. It abuses the browser's automatic inclusion of session credentials.
3. Anti-CSRF tokens bind a state-changing request to an expected session or form.
4. SameSite cookie settings and Origin/Referer validation can provide additional defenses.
5. State-changing actions should not rely on GET requests.
6. CSRF is distinct from XSS, although XSS can sometimes bypass CSRF protections.

Q34. What is authentication versus authorization?

1. Authentication verifies who a user or system is.
2. Authorization determines what an authenticated identity is allowed to do.
3. Passwords, passkeys, and MFA are authentication mechanisms.
4. Roles, permissions, and policy checks support authorization.
5. Broken authentication can permit account compromise; broken access control can expose another user's data.
6. Enforce authorization on the server for every protected object and action.

Q35. What is IDOR or broken object-level authorization?

1. IDOR occurs when changing an object reference exposes data or actions without proper authorization.
2. An identifier may be numeric, a UUID, a filename, or another token.
3. Complex or random identifiers do not replace access-control checks.
4. Test with accounts you control and objects within the approved scope.
5. The server must verify that the current user may access the requested object.
6. Fix by enforcing object-level authorization on every relevant request.

Q36. What is password hashing, and how is it different from encryption?

1. Hashing is a one-way transformation designed for verification, not direct recovery.
2. Encryption is reversible when the correct decryption key is available.
3. Passwords should be stored using a dedicated password-hashing scheme.
4. Argon2id, bcrypt, and scrypt are commonly used password-hashing choices.
5. Unique salts help prevent identical passwords from producing identical stored hashes.
6. Fast general-purpose hashes such as plain SHA-256 are not suitable alone for password storage.

Q37. What is multi-factor authentication?

1. MFA requires at least two different categories of proof.
2. Categories include something you know, have, or are.
3. A password plus a separate authenticator factor is an MFA example.
4. Phishing-resistant methods such as FIDO2/WebAuthn security keys provide strong protection.
5. SMS codes are generally weaker because of risks such as SIM swapping and interception.
6. MFA reduces risk but does not eliminate session theft or every account attack.

Q38. What is SSH, and how do you use it securely?

1. SSH provides encrypted remote login and related secure channel functions.
2. `ssh user@host` connects to a remote host.
3. `scp file user@host:/path/` securely copies a file over SSH.
4. SSH keys can reduce reliance on passwords when managed securely.
5. Verify host keys to reduce the risk of connecting to an impersonated server.
6. Restrict access, patch the service, and protect private keys with suitable permissions.

Q39. What is Wireshark used for?

1. Wireshark captures and analyzes network packets.
2. It helps troubleshoot protocols, connection failures, DNS, and suspicious traffic.
3. Capture filters reduce which packets are collected; display filters narrow what is shown.
4. `dns` is a display filter for DNS packets.
5. `tcp.port == 443` filters packets with TCP source or destination port 443.
6. Captures may contain credentials or personal data, so collect and store them lawfully and securely.

Q40. What is ARP?

1. ARP maps an IPv4 address to a link-layer address on a local network.
2. A host broadcasts an ARP request when it needs a local IPv4 neighbor's MAC address.
3. The target normally responds with an ARP reply.
4. ARP is for local-link resolution and is not routed across the internet.
5. ARP spoofing can mislead devices about IP-to-MAC mappings on susceptible networks.
6. Mitigations include network segmentation, switch protections, and monitoring where supported.

Q41. What is the OSI model?

1. Layer 1 Physical: signals and physical media.
2. Layer 2 Data Link: frames, MAC addressing, and switching.
3. Layer 3 Network: IP addressing and routing.
4. Layer 4 Transport: TCP/UDP ports and transport behavior.
5. Layers 5–7 are Session, Presentation, and Application; examples include application protocols at Layer 7.
6. The model is a troubleshooting framework; real protocol stacks do not always map perfectly to it.

Q42. What is the difference between IDS and IPS?

1. An IDS detects suspicious activity and raises alerts.
2. An IPS can actively block or drop traffic inline.
3. Both may use signatures, behavior analysis, and protocol inspection.
4. False positives can overwhelm analysts or block legitimate activity.
5. Detection quality depends on visibility, tuning, updates, and context.
6. Use alert triage and controlled testing to verify whether rules behave as intended.

Q43. How do you investigate a suspicious Linux process?

1. Record the process ID, owner, command line, parent process, and start time.
2. Use `ps aux`, `pgrep -a name`, and `top` to inspect processes.
3. Use `ss -tulpen` and tools such as `lsof -p PID` when available to inspect network and file activity.
4. Check executable paths, hashes, persistence mechanisms, and relevant logs.
5. Preserve evidence before killing or deleting a suspected process when incident procedures require it.
6. Isolate affected systems according to policy and escalate rather than running unknown files.

Monitoring, reporting, and practical workflow

Q44. What is least privilege?

1. Least privilege grants only the access needed for a task.
2. It limits damage from compromised accounts, applications, and mistakes.
3. Use separate standard and administrative accounts where appropriate.
4. Grant narrowly scoped file, database, cloud, and network permissions.
5. Review access regularly and remove stale accounts or privileges.
6. Validate permissions through testing and logs, not just assumptions.

Q45. How do you write a useful VAPT finding?

1. Give the finding a clear title and affected asset or endpoint.
2. Describe the weakness and the conditions required to reproduce it.
3. Provide minimal, safe evidence such as relevant requests, responses, or screenshots.
4. Explain impact in business terms and assign severity using a consistent method.
5. Recommend a specific remediation and any compensating controls.
6. Retest after remediation and document whether the issue is fixed, partial, or unresolved.

Q46. What is responsible disclosure and why is scope important?

1. Responsible disclosure communicates a vulnerability to the appropriate owner in a controlled way.
2. Scope defines approved systems, methods, accounts, time windows, and prohibited actions.
3. Authorization should be explicit before scanning or exploitation.
4. Avoid destructive actions, unnecessary data access, persistence, or service disruption.
5. Keep evidence minimal and protect any sensitive data encountered.
6. Follow the engagement rules and report unexpected high-risk findings promptly.

Q47. How would you approach a basic authorized web application assessment?

1. Confirm written authorization, scope, test accounts, and prohibited techniques.
2. Map the application and record endpoints, roles, and important workflows.
3. Use browser developer tools or Burp Proxy to understand requests and responses.
4. Check authentication, session handling, access control, input validation, and security headers.
5. Validate findings with safe, repeatable evidence and avoid unnecessary data changes.
6. Prioritize remediation, communicate risks, and retest fixes.

Q48. What should you do when Nmap reports a host as down?

1. Do not assume the host is truly offline; discovery probes may be blocked.
2. Confirm the target address, DNS resolution, and approved scope.
3. Check local routing with `ip route` and basic connectivity where appropriate.
4. With authorization, try `nmap -Pn target` to skip host discovery.
5. Consider firewalls, VPNs, NAT, rate limits, and network segmentation.
6. Record the exact scan options and vantage point because they affect the result.

Q49. What is the difference between open, closed, and filtered ports in practical terms?

1. Open: a service appears to accept connections on that port.
2. Closed: the target responds, but no service appears to be listening.
3. Filtered: probes are blocked or unanswered enough that the state cannot be determined.
4. Open ports should be mapped to expected services and business need.
5. Unexpected exposure may require firewall review, service hardening, or patching.
6. Validate findings from the relevant network location; internal and external results can differ.

Q50. How do you safely practice cybersecurity skills as a beginner?

1. Use purpose-built labs, intentionally vulnerable applications, or systems you own.
2. Read the lab rules and understand the objective before running tools.
3. Start with basic commands and interpret each option rather than copying blindly.
4. Keep notes containing commands, observations, limitations, and fixes.
5. Use snapshots or disposable environments to recover from mistakes.
6. Never scan or exploit third-party systems without explicit authorization.